Análisis estático y de dependencias

Resultados SAST/SCA — Ronda 3

Equipo SOS Clinic

22 de octubre de 2026

1 Resumen

Escaneo	Resultado	Evidencia
Gitleaks árbol	0 hallazgos (15,72 MB)	`gitleaks-arbol-r3.json`
Gitleaks historial	3 hallazgos históricos (45 commits)	`gitleaks-historial-r3.json`
Semgrep	9 hallazgos, todos en scripts de prueba	`semgrep-r3.json`
Trivy dependencias	0 vulnerabilidades en 7 `pom.xml`	`trivy-r3.json`
Trivy configuración	0 archivos detectados	`trivy-config-r3.json`

Cuadro 1: Resumen del análisis estático.

2 Gitleaks

Árbol de trabajo

No hay secretos en el árbol versionado. El archivo `.env` local está ignorado por Git y no aparece en el escaneo. El resultado es consistente con la regla de no versionar credenciales.

Historial

Aparecen tres coincidencias de la regla `grafana-api-key` en `frontend/enfermedades-crue.html`, en los commits `d0fb56f` y `42f9d31`. El archivo ya no existe en el árbol actual, por lo que no hay exposición vigente. Si el valor fue una clave real, debe rotarse: eliminarlo del árbol no lo borra del historial.

3 Semgrep

Los 9 hallazgos están en scripts de prueba, no en código de producción:

No se encontraron patrones de inyección, deserialización, criptografía débil ni ejecución de comandos en el código de los servicios.

4 Trivy

- **Dependencias:** 0 vulnerabilidades, 0 secretos y 0 configuraciones inseguras en los siete `pom.xml`. Se usó la caché local de Maven porque la primera ejecución recibió HTTP 429 de Maven Central.
- **Configuración:** Trivy no detectó archivos de configuración en `infra/`. La revisión manual confirma que PostgreSQL y pgAdmin publican solo en `127.0.0.1`, que las contraseñas son obligatorias por `.env` y que `spring.jpa.show-sql=false`.

Regla	Archivos	Evaluación
`detected-bcrypt-hash` (3)	`e2e_claves.py`, `e2e_funcional.py`, `pentest_local.py`, `pentest_xss.py`	Falso positivo: hash de la clave de fixture de cuentas temporales.
`dynamic-urllib-use` (6)	`verify_seed.py` y scripts E2E	Falso positivo: URLs fijas de `localhost` o configuración controlada.

Cuadro 2: Hallazgos de Semgrep y su clasificación.

5 Hallazgos y mejoras

- **Histórico:** rotar la clave Grafana si fue real y documentar la decisión sobre el historial.
- **Pruebas:** los hashes de fixture pueden marcarse con `nosemgrep` o generarse en tiempo de ejecución para reducir ruido.
- **CI:** ampliar el job de gitleaks al historial y publicar los reportes de Semgrep/Trivy como artefactos.
- **Configuración:** añadir un escaneo explícito del compose o usar una versión de Trivy que lo detecte.

6 Conclusión

No hay secretos vigentes ni vulnerabilidades conocidas en las dependencias. Los únicos hallazgos del análisis estático son históricos o falsos positivos demostrables en scripts de prueba. El estado es apto para continuar con las pruebas dinámicas y el pentest.